Asset driven ISO/SAE 21434 compliant Automotive Cybersecurity Analysis with ThreatGet

Christoph Schmittner[1][0000−0003−4430−6813], Bernhard Schrammel[2], and Sandra König[1][0000−0003−2881−4519]

[1] AIT Austrian Institute of Technology GmbH, Giefinggasse 4, 1210 Wien
christoph.schmittner@ait.ac.at https://www.ait.ac.at/en/research-topics/dependable-systems-engineering/safety-security
[2] msg Plaut Austria GmbH, Modecenterstraße 17, Marximum 4/6, 1110 Wien
Bernhard.Schrammel@msg-plaut.com
https://www.msg-plaut.com/automotive/automotive-security

Abstract. With the trend towards connectivity and automation in the automotive domain, automotive cybersecurity and the protection against cyber attacks is increasingly important. This is mirrored in the upcoming regulation on cybersecurity for UNECE Type Approval. Therefore a structured and systematic approach to automotive cybersecurity risk management is needed.
Risk management in general focuses on, *What to protect* and *How could it be damaged*. The combination of these allows to identify and rate existing cybersecurity risks and enables further steps of risk management. Risk management in the automotive domain will be based on an international standard that is currently developed. The draft of ISO/SAE 21434 was published in 2020 and the publication of the final version is expected in 2021.
This standard does not describe a strict risk management approach but rather defines a framework of activities which need to be conducted, without specifying a process or methods. It is therefore important to investigate existing approaches, consider the guidance in standards and regulation and apply and evaluate resulting processes and methods.
We report here experiences collected during the application of an asset driven automotive cybersecurity analysis with the Tool ThreatGet which is compliant with ISO/SAE 21434. The considered use cases for this application is a gateway and communication ECU developed by TTControl.

Keywords: Automotive Security · gateway and communication ECU · ISO/SAE 21434.

1 Introduction

While the history of automotive began in the 17th-century [9] automotive security only started at the beginning of the 20th century. The first keys in cars

were installed in 1910 and locked only the electric circuit for ignition. This was followed by keys for car doors in 1920 and keys that started the ignition in 1949. Automotive security moved towards electric security in 1986 when a resistor with a "secret" value was integrated into the keys. With the introduction of key-less entry systems in 1993, remote start and control in 2004 and finally smartphones for key-less go in 2018 automotive security moved towards cybersecurity [21]. With this, the focus of protection shifted from the car as value to the internal data, systems, software and configuration. Protecting them is necessary to ensure safety of the road user, protect privacy of Personally Identifiable Information (PII) and ensure availability and unrestricted operation of the vehicle as a mobility solution. Also, the intellectual property of the entities involved in the automotive supply chain is increasingly stored in the vehicle and constitutes a relevant target for the attacker. All these "valuable" things can be summarized as assets. An asset is anything that has value for a stakeholder in the automotive ecosystem and therefore needs protection.

Besides, ways to attack vehicles evolved from physical attacks on the keyhole towards cyber-attacks on local or remote interfaces. Research even showed that attacks can be performed independent of the location via the Internet and manipulate vehicle functions [5]. This lead to the development of an international standard for automotive cybersecurity engineering [19] and a set of regulations regarding the type approval of automotive cybersecurity [18].

In comparison to existing automotive standards like the ISO 26262 [2] the ISO/SAE 21434 [3] does not describe a process or methods for risk management. The standard gives a set of activities with objectives for the activities and leaves the decision on the order of activities, process and methods to utilize to the user. This was done since the state of the art in automotive cybersecurity was considered as not as mature compared with safety.

For the development of ISO 26262, experience with the application of IEC 61508 in the automotive sector could be utilized [16]. In comparison to this for the development of ISO/SAE 21434, only experience from research projects and company internal approaches were existing. Other security standards were either considered as not directly applicable or still in development when the work on ISO/SAE 21434 was started.

Due to this, it is important to consider the requirements regarding objectives and activities in ISO/SAE 21434 and to build a compliant approach for automotive cybersecurity risk management. While there is pre-existing work, this often focuses only on parts of the required activities or was developed before the publication of ISO/SAE DIS 21434. We address the question of **structure and methods for a usable process for automotive cybersecurity risk management.**

In the following, we present a tool-supported and asset driven approach to identify, rate and control cybersecurity risks based on a real-world example of a vehicular telematics gateway.

2 State of the Art

In comparison to SAE J3061 [7], ISO/SAE 21434 proposes only an unsorted list of activities for cybersecurity risk management. For each activity, objectives are given and the standard contains an informative example on which different ways to realize the activities are shown. Figure 1 gives a proposed overview of how the results from the activities in ISO/SAE 21434 are related.

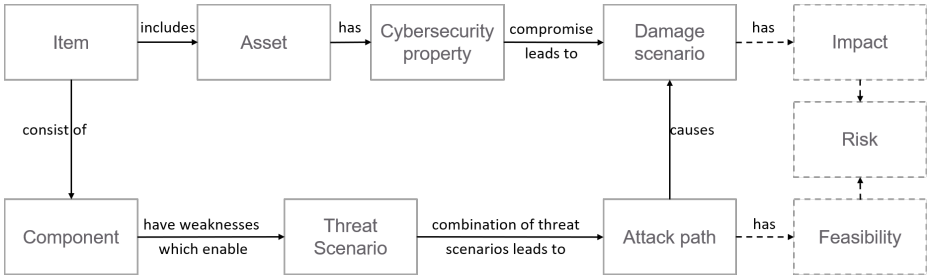

Fig. 1. Overview of elements and proposed relations

The list of activities from ISO/SAE 21434 is the following:

- Asset identification
- Threat scenario identification
- Impact rating
- Attack path analysis
- Attack feasibility rating
- Risk value determination

Considering this we can evaluate existing approaches and consider their potential contribution.

While SAE J3061 [7] did not include process or activities for cybersecurity risk management, it presented multiple methods which could be relevant for a Threat Analysis and Risk Assessment (TARA). Evaluations of these methods showed weaknesses and difficulties in directly applying such methods to the automotive domain [12].

SAHARA [13] and FMVEA [20] are adaptions of the Hazard Analysis and Risk Assessment (HARA) and Failure Mode and Effects Analysis (FMEA) with regards to security. They address specific steps but do not present a complete process approach that includes all activities from ISO/SAE 21434.

EVITA [10] and HEAVENS [11] were research projects with a focus on automotive security with a major impact. While concepts and approaches from these projects are still in usage and integrated into ISO/SAE 21434, there are also lessons learned due to the ongoing application [8] which do not support an unmodified application.

For our approach we utilized SAHARA during the Asset identification and the HEAVENS Impact and Threat Level adapted to ISO/SAE 21434 compliance for risk evaluation. This was extended with the Asset-based approach and an automated and rule-engine based determination of Threats and Attack paths.

3 Use Case

We consider here the use case of an vehicular telematic gateway [6]. Such an item takes the role of connectivity element to connect the internal elements of the vehicle with external services and offers vehicle configuration and entertainment and navigation to the user. TTControl develops such systems for usage by different vehicle manufacturer. This means, the item is developed based on assumptions and for the configuration and adaption in the target vehicle these assumptions need to be validated.

An *item* is a term introduced by ISO 26262 [2] and further used by ISO/SAE 21434 [3], describing a system or combination of systems, enabling a function on the vehicle level. Item definition for safety and Item definition for security are overlapping but not identical [19].

An concept level diagram of the item is shown in Fig. 2.

Regarding the definition of the use case, the following information can be added as a abbreviated form of Item definition as required by ISO/SAE 21434:

1. Item boundary: The item contains the telematic gateway with the following interfaces
   - User Interface (HMI) is used for local access to system functions.
   - Ethernet is used for the provisioning of the system and for future on-board connectivity (automotive Ethernet).
   - USB is used for updates of the system or connected ECU.
   - WLAN/GSM is used for remote maintenance and Over-the-Air updates of the system or connected ECU.
   - CAN connects the system to the rest of the on-board network.
2. Item functions are:
   - local and remote read out and configuration of vehicle data.
   - local and remote update of system and connected ECU.
   - NOTE: while the item can be used for navigation and entertainment, this is not considered in the basic functionalities provided with the item
3. Preliminary Architecture is shown in Fig. 2
4. Operational environment:
   - Item is installed inside the vehicle in a casing.
   - USB and Ethernet interfaces are covered with a protective cap but accessible.
   - Item is connected to an backend which will manage access to data and configuration. Direct access to the item via the internet is not intended. The backend is assumed to be secured.

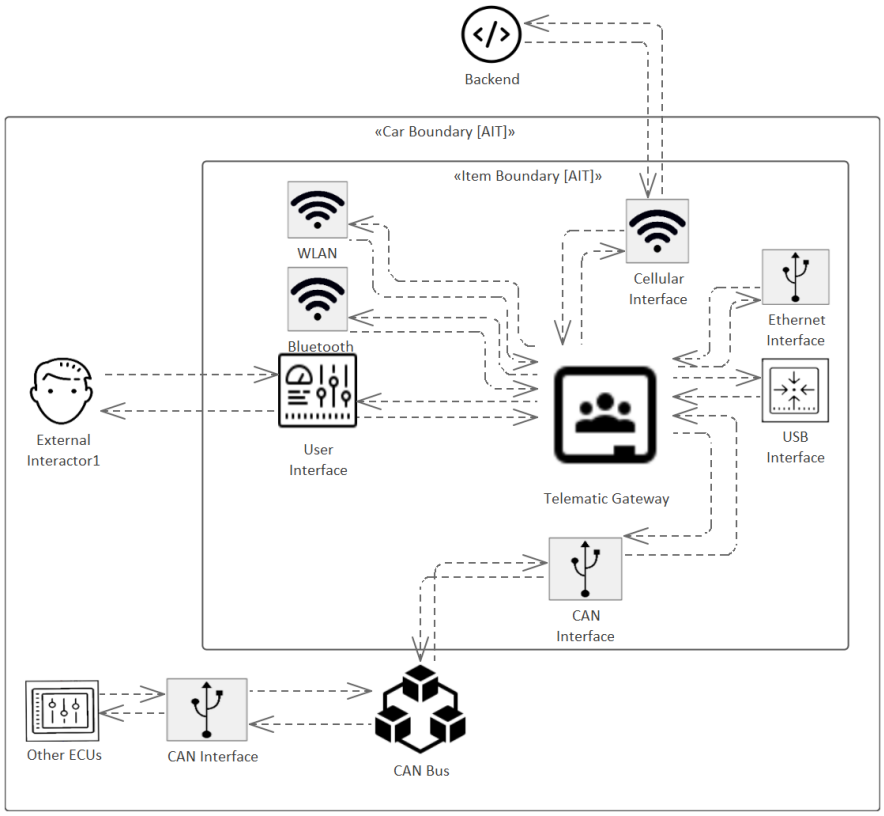

Fig. 2. Concept level diagram of the telematic gateway

4 Asset driven Automotive Cybersecurity Analysis with ThreatGet

Figure 2, Concept level diagram of the telematics gateway, as well as the following steps in the cybersecurity analysis process, will be conducted using ThreatGet [3] [17]. ThreatGet is a threat analysis and risk management plugin for the modelling platform Enterprise Architect. ThreatGet was developed by AIT Austrian Institute of Technology in cooperation, regarding the commercialisation, with LieberLieber. We report here on the application and usage done in cooperation with the ThreatGet partner MSG Plaut for a TTControl use case [14].

ThreatGet is a plugin for the widely used and well-accepted modelling platform Enterprise Architect. It provides a set of domain-specific modelling elements (Automotive toolbox) with security-related properties and security controls. With this, a system and its assets can be modelled. Based on a set of rules

[3] https://www.threatget.com/

about weaknesses, potential attacks, threats and attack paths the system model can be analysed and threats can be detected.

We follow here a asset driven process (as shown in Fig. 3), motivated by similarities to the safety process and with the goal to focus early on critical parts of the considered system.

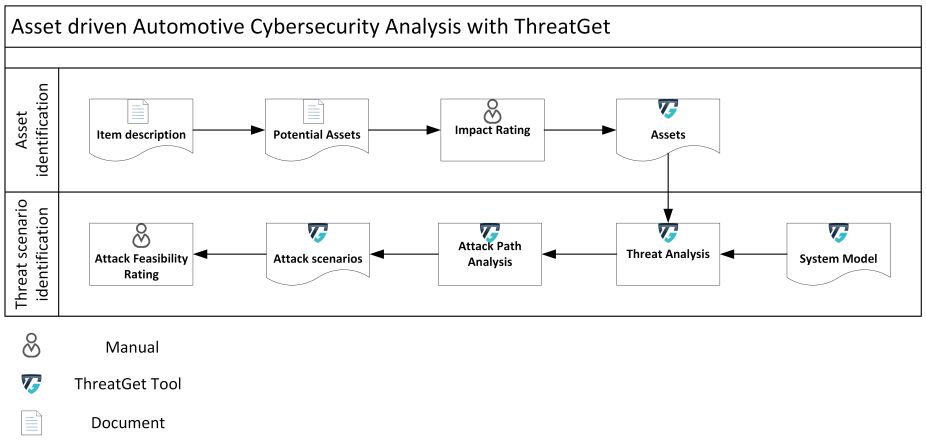

Fig. 3. Methodology for Asset driven Automotive Cybersecurity Analysis with ThreatGet

With this approach the focus is on first identifying the assets and assigning the assets to the respective elements in the system model. Based on this only elements which contain an asset are considered for the threat analysis as final steps. Elements which do not contain or contribute to an asset are only considered as potential weaknesses or attack steps for an attack path.

4.1 Asset identification

The following assets were identified based on previous projects, brainstorming, and discussion with experts regarding cybersecurity and the system. Since Assets, their cybersecurity properties and the damage scenarios can be compared to Hazards we utilized here also SAHARA [13] and applied the STRIDE guidewords to functions, data, software and elements in the system.

A1 Remote maintenance and update functions
A2 Remote control and access to HMI
A3 Communication interface to on-board network
A4 Configuration data
A5 Internal IP

For each of the assets, the relevant cybersecurity properties (confidentiality, integrity and availability, CIA) are identified. This is done based on damage

scenarios, which describe the potential effect of a violation of the respective cybersecurity property. An overview is shown in table 1. Due to page limitations, neither the list of assets nor the damage scenarios and cybersecurity properties are complete.

An asset is defined by having at least one cybersecurity property for which a damage scenario can be identified. If the brainstorming identifies a potential asset for which no damage scenario can be found this asset will not be pursued further.

Impact rating Regarding the impact rating ISO/SAE 21434 prescribes the categories Safety, Financial, Operational, and Privacy (SFOP), all evaluated from the viewpoint of the road user and rated on a scale. For safety, it is recommended to utilize severity and controllability as defined in ISO 26262. For the other categories, scales can be defined and the list of categories can be extended. We utilize the following Impact Level (IL) scale:

No impact > Low > Medium > High > Critical

Table 1 shows an exemplary overview of assets with cybersecurity properties and the identified damage scenarios with impact category and rating.

Table 1. Example list of assets and damage scenarios with impact

Assets	C	I	A	Damage Scenarios	Impact category	Impact rating
A3 Communication interface to on-board network		x		Telematic gateway is used to send manipulated data to other ECU, causing potentially unsafe actions	S	Critical
			x	Connection to on-board network is not available, remote maintenance and updates for other ECU is not available	O	Low
A4 Configuration data		x		The attacker is able to manipulate configuration data to potentially unsafe parameters	S	High
			x	Configuration data is deleted and telematic gateway functionality is lost	O	M
A5 Internal IP	x			Competitor gets access to internal IP for reverse engineering or usage	F	Critical

For the "Internal IP" asset, the damage scenario is from the viewpoint of the vehicle manufacturer or supplier. While this is not required by ISO/SAE 21434 we recommend considering this stakeholder and viewpoint.

4.2 Threat scenario identification

For the threat scenario identification we utilize the threat database in ThreatGet. Threats from internal security evaluations and threat lists from UNECE [18] to

ETSI, CVE and ITU are included and described in a domain specific security analysis language. The previously shown concept diagram is extended with the assets in order to enable the automated identification of threat scenarios. The extended diagram is shown in Fig. 4.

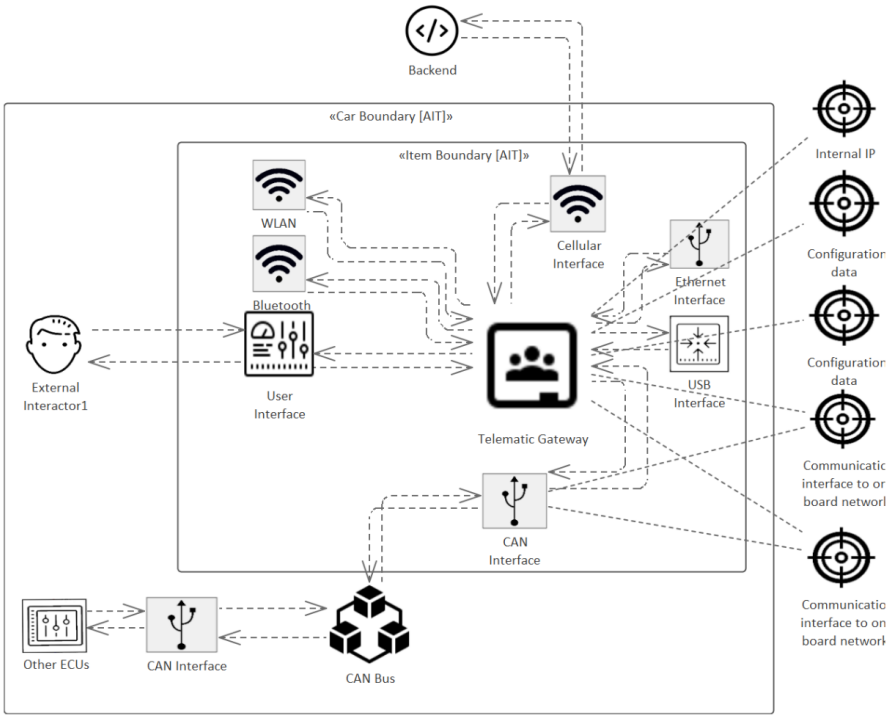

Fig. 4. Concept level diagram with assets

Each damage scenario for an asset is described in a model element. This is used for documentation (to generate complete artifacts) for traceability (to trace assets, damage scenarios, and threats to risks and risk management), and for automated analysis (to identify threats based on the cybersecurity property). One example for this is shown in figure 5.

Threat analysis Each threat in the ThreatGet threat database is assigned a STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) category [22]. Due to the linkage from STRIDE to CIA[3], the STRIDE classification of threats enables ThreatGet to automatically identify which threat can trigger a certain damage scenario by having the fitting STRIDE type which can violate the cybersecurity property.

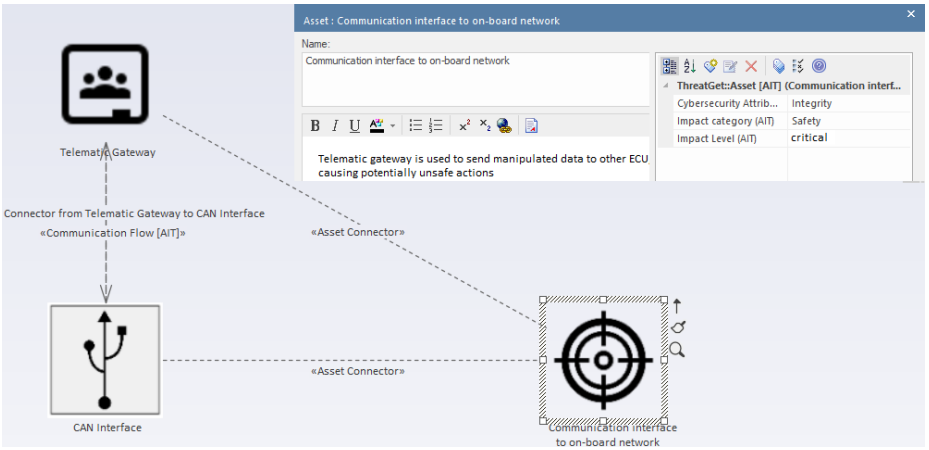

Fig. 5. Example asset

Depending on the level of detail in the system model the attack feasibility or Threat Level (TL) can either be rated based on the identified threats or if a model with more details is available an attack path analysis can be conducted.

For a detailed diagram a sub diagram of the telematic unit can be generated in Enterprise Architect. This takes the existing connection and allows to model the internal workings of the control unit (see Figure 6).

Regarding the threat scenario identification, the goal is to identify potential weaknesses in the design or configuration which allows an attacker to trigger a damage scenario. For this, we configure model elements and data flows in the diagram with the relevant security properties and identify weaknesses based on the threat database.

Regarding our use case, the secondary CPU can be tampered with and also a Denial of Service is feasible. Data stored on the SD Card is not protected against manipulation, deletion or readout.

Attack path analysis After the identification of potential threat scenarios, a subsequent analysis identifies potential attack paths. An attack path describes a path from an interface to an element where a threat scenario can be triggered.

For this, ThreatGet can describe attack flows with missing security controls in the flow, describing a generic path from an interface to a threat scenario through an arbitrary number of elements. In this way a system model can be described in different sets of granularity and a rule can be described without having prior knowledge of the model.

An example here is the Bluetooth interface which has no protocol version defined and is therefore assumed to be running a vulnerable protocol version. From there, an attacker would be able to access the main ECU which is also not protected against tampering. Tampering with the main ECU allows an attacker to access the unprotected communication between the main ECU and secondary

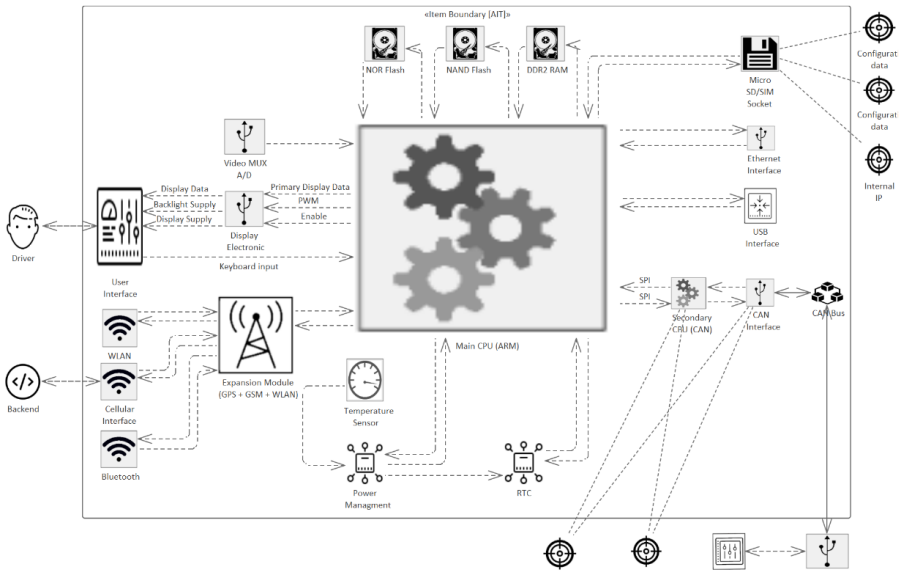

Fig. 6. System level diagram

ECU and send commands to the secondary ECU which trigger the damage scenario of "Telematic gateway is used to send manipulated data to other ECU, causing potentially unsafe actions". In addition to the fact that elements and data flows are not secured, the attack flow features also checks that there is no firewall or gateway with appropriate security measures in the flow.

For an attack path analysis ThreatGet marks the attack path and the affected elements in the analysis as shown in Figure 7.

Attack feasibility rating Based on the interface the attack path uses as an attack surface and the taken path the attack feasibility is rated. We utilize for the rating of the attack feasibility the Threat Level (TL). The Threat Level is based on the attack potential assessment introduced in [1]. Regarding the Threat Level (TL) we utilize the following scale:

None < Low < Medium < High < Critical

ISO/SAE 21434 offers also an attack vector-based approach which rates the attack feasibility only regarding the accessibility of the interface and is more suitable if only the concept level diagram is available (Concept diagram 2). Due to the higher level of details available in the system level diagram (System diagram 6) we utilize an attack potential based approach.

To determine the TL the following factors are considered: Elapsed Time (ET), Specialist Expertise (SE), Knowledge of the Item or Component (KoIC), Window of Opportunity (WoO) and Equipment (Eq). We give an example rat-

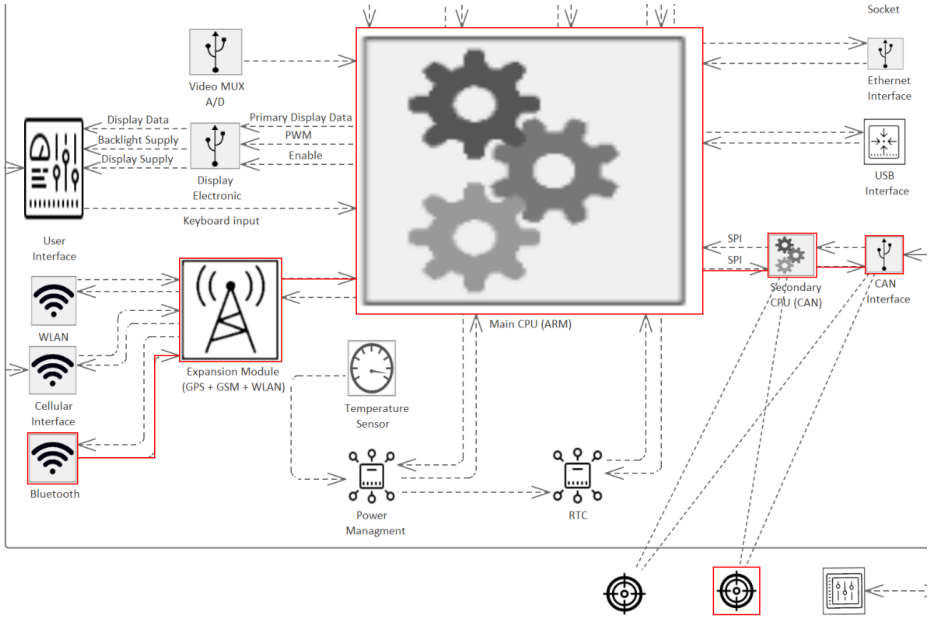

Fig. 7. Result of attack path analysis

ing for the presented attack path in table 2. The chosen rating depends on examples given in ISO/SAE 21434 (e.g. Window of Opportunity rating given for Bluetooth) and the similarities to the well-published Jeep Cherokee Attack in regards to the way how CAN message can be sent [5].

In all cases such ratings need to be adapted and include assumptions about the attacker. For example if we consider the damage scenario "Competitor gets access to internal IP for reverse engineering or usage" the Window of Opportunity for this scenario would be unlimited (0) since here an competitor would source a vehicle for this. With an unlimited access the task would be more on how to impede such attacks to a sufficient level.

4.3 Risk value determination

Regarding the risk value determination, Impact Level (IL) and Threat Level (TL) are combined in a risk matrix as shown in Table 3.

Risk matrices can be adapted to the risk appetite of an organization and the respective use case. The chosen example here assigns a low risk to critical attack paths, even if there is no impact on an asset involved. This was done to manage and trace such attack paths in cybersecurity engineering due to the potential of enabling further attacks. Similar critical assets, even without a feasible attack path, are further tracked.

Table 2. Examples of Threat Level rating with the attack potential-based approach

Threat scenario	Attack path	Threat Level assessment						
		ET	SE	KoIC	WoO	Eq	**Sum**	TL
Tampering with sent CAN messages	i. Attacker accesses Bluetooth Interface with unspecified protocol ii. Attacker compromises Main ECU due to not requiring authentication or authorization and having update capabilities without ensuring that the software has not been tampered iii. Communication between Main ECU and Secondary ECU allows sending commands without authentication or authorization and is not encrypted iv. Attacker is able to send manipulated data to other ECU, causing potentially unsafe actions	1	3	7	1	0	**12**	Critical

Table 3. Example Risk Matrix

Security Level	Impact Level (IL)					
Threat Level (TL)		No impact	Low	Medium	High	Critical
	None	QM	QM	QM	QM	Low
	Low	QM	Low	Low	Low	Medium
	Medium	QM	Low	Medium	Medium	High
	High	QM	Low	Medium	High	High
	Critical	Low	Medium	High	High	Critical

The considered example with IL: critical and TL: critical would result in a critical risk that requires further actions. It is recommended to address risks with more than one security control, such approaches are collectively called "defence in depth" [4].

5 Conclusion

We presented here an approach towards an ISO/SAE 21434 compliant cybersecurity analysis for a telematics gateway system, driven by asset identification. Assets are intangible goods, defined by the potential that a violation of a cybersecurity property leads to a damage scenario with a certain impact. On the other side, assets are the target of all assumed attackers. While scientific and benevolent attackers (security researchers and white hat hacker) develop attacks based on curiosity, dangerous attackers have a certain motivation which is in most cases an asset or damage scenario. Therefore it is essential to investigate assets not only for the determination of the impact but also for the identification of attacker paths.

We call this an asset driven automotive cybersecurity analysis and give an overview of relations in Figure 8.

This approach is compatible with other risk identification and risk rating schemes. The core principle is a strong focus on the assets as goods to protect where an attacker is looking for ways to attack. Here it is also essential to place security controls in a layered approach and to achieve protection of multiple assets with security controls.

The identification of assets was an often underestimated activity. Although in repeated analysis, the time required for asset identification was reduced, due to the reuse of existing assets and more experience of the participants, a well-done analysis of all assets is an essential step in this approach. Elements without assets are only considered as stepping stones in attack paths and no impact is assigned to them. Security goals are also aimed at the protection of assets and defence against attack paths.

The interaction between defender and attacker can be interpreted as a competitive endeavour. The defender aims for a sufficient defence of an asset. The resources to spend are restricted and all assets should be sufficiently protected, based on their respective risks. The attacker aims to cause damage while limiting the amount of resources spent. This strategic interaction can be represented as a game where the analysis of the behaviour of the player may as well be supported by vulnerability analysis and attack graphs [15].

Acknowledgements This project has received funding from the ECSEL Joint Undertaking (JU) under grant agreement No 783221 (AFarCloud). The JU receives support from the European Union's Horizon 2020 research and innovation programme and Austria, Belgium, Czech Republic, Finland, Germany, Greece, Italy, Latvia, Norway, Poland, Portugal, Spain, Sweden. Parts of this work were funded by the Austrian Research Promotion Agency (FFG) and BMK (Austrian Federal Ministry for Climate Action, Environment, Energy, Mobility, Innovation and Technology).

References

1. Common Methodology for Information Technology Security Evaluation - Evaluation methodology (Sep 2012)
2. 32, I.S.: Iso 26262-1:2018 road vehicles — functional safety. International Organization for Standardization (2018)
3. 32, I.S.: Iso/sae fdis 21434: Road vehicles — cybersecurity engineering. International Organization for Standardization, SAE International (2020)
4. Breuing, H., Heil, L., Vierling, B.: It security for the entire automotive ecosystem. ATZelectronics worldwide **14**(7), 60–63 (2019)
5. Charlie Miller, Chris Valasek: Remote Exploitation of an Unaltered Passenger Vehicle. Tech. rep., Black Hat 2015 (Aug 2015)
6. Cho, K., Bae, C., Chu, Y., Suh, M.: Overview of telematics: A system architecture approach. International Journal of Automotive Technology **7**(4), 509–517 (2006)

7. Committee, S.V.E.S.S., et al.: Sae j3061-cybersecurity guidebook for cyber-physical automotive systems. SAE-Society of Automotive Engineers (2016)
8. Consortium, H.: Tailoring the heavens risk assessment methodology for improved performance (03 2018)
9. Eckermann, E.: World history of the automobile. SAE (2001)
10. Henniger, O., Ruddle, A., Seudié, H., Weyl, B., Wolf, M., Wollinger, T.: Securing vehicular on-board it systems: The evita project. In: VDI/VW Automotive Security Conference. p. 41 (2009)
11. Islam, M.M., Lautenbach, A., Sandberg, C., Olovsson, T.: A risk assessment framework for automotive embedded systems. In: Proceedings of the 2nd ACM International Workshop on Cyber-Physical System Security. pp. 3–14 (2016)
12. Macher, G., Armengaud, E., Brenner, E., Kreiner, C.: A review of threat analysis and risk assessment methods in the automotive context. In: International Conference on Computer Safety, Reliability, and Security. pp. 130–141. Springer (2016)
13. Macher, G., Sporer, H., Berlach, R., Armengaud, E., Kreiner, C.: Sahara: a security-aware hazard and risk analysis method. In: 2015 Design, Automation & Test in Europe Conference & Exhibition (DATE). pp. 621–624. IEEE (2015)
14. Mürling, M.W.: Security by design: New "threatget" tool tests cyber security in vehicles and systems (2021), https://www.ait.ac.at/news-events/single-view/detail/6743?cHash=b6d28cc455fff1a63b7a25530dd6b00b
15. Rass, S., König, S., Schauer, S.: Defending against advanced persistent threats using game-theory. PloS one **12**(1), e0168675 (2017)
16. Rivett, R.S.: Hazard identification and classification: Iso26262-the application of iec61505 to the automotive sector. In: 2009 5th IET Seminar on SIL Determination. pp. 1–24. IET (2009)
17. Schmittner, C., Chlup, S., Fellner, A., Macher, G., Brenner, E.: Threatget: Threat modeling based approach for automated and connected vehicle systems. In: AmE 2020-Automotive meets Electronics; 11th GMM-Symposium. pp. 1–3. VDE (2020)
18. Schmittner, C., Dobaj, J., Macher, G., Brenner, E.: A preliminary view on automotive cyber security management systems. In: 2020 Design, Automation & Test in Europe Conference & Exhibition (DATE). pp. 1634–1639. IEEE (2020)
19. Schmittner, C., Griessnig, G., Ma, Z.: Status of the development of iso/sae 21434. In: European Conference on Software Process Improvement. pp. 504–513. Springer (2018)
20. Schmittner, C., Ma, Z., Smith, P.: Fmvea for safety and security analysis of intelligent and cooperative vehicles. In: International Conference on Computer Safety, Reliability, and Security. pp. 282–288. Springer (2014)
21. Service, B.M.: Bosch presents the history of the car key (Jun 2019), https://www.bosch-presse.de/pressportal/de/en/bosch-presents-the-history-of-the-car-key-191680.html
22. Shostack, A.: Experiences threat modeling at microsoft. MODSEC@ MoDELS **2008** (2008)

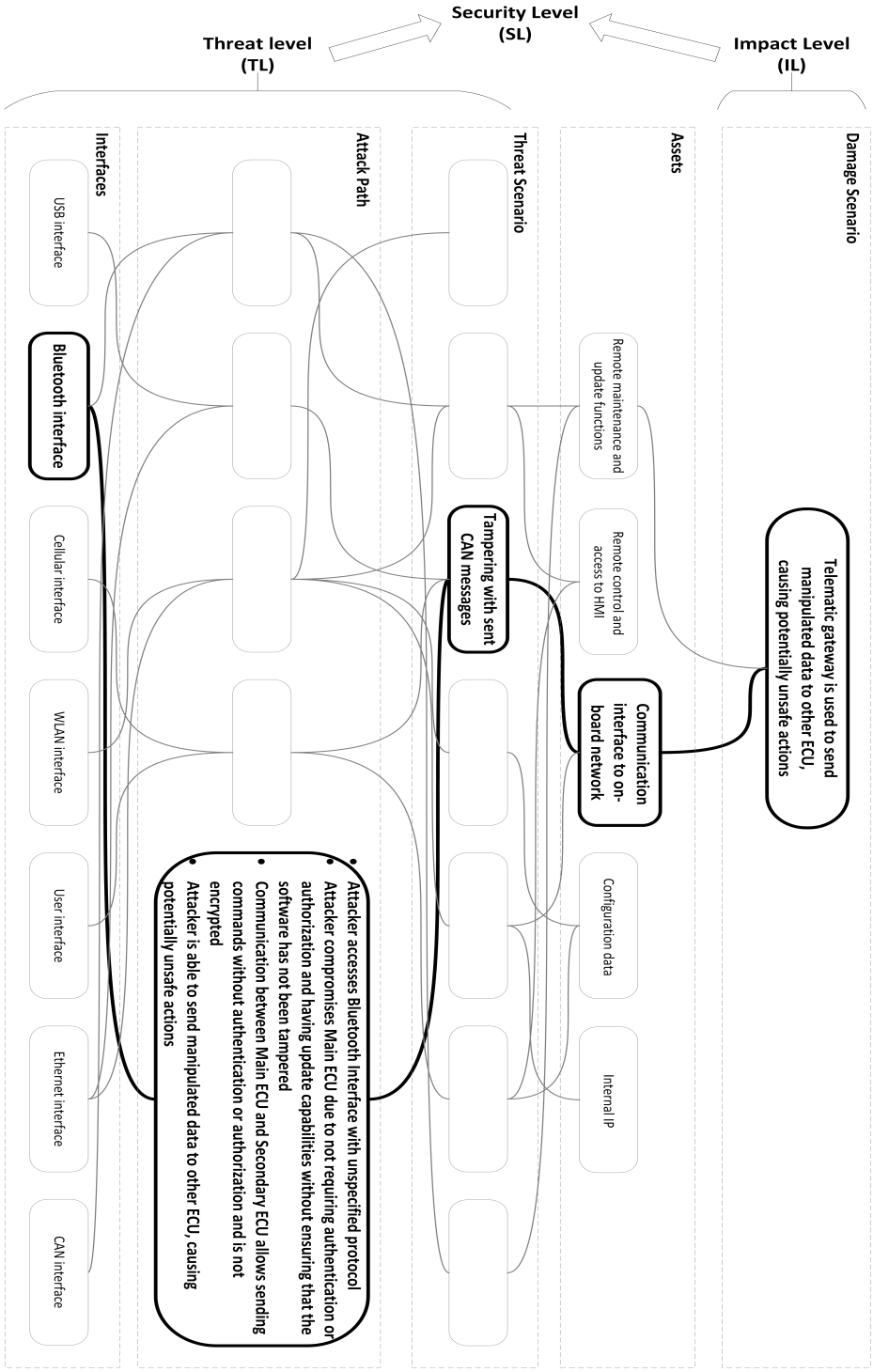

Fig. 8. Asset driven automotive cybersecurity analysis